

Section 1: Executive Summary

The Grand Marina Hotel relies on Hydroficient's HYDROLOGIC system to manage water pressure and flow across three critical lines — the main guest building, the pool and spa, and the commercial kitchen and laundry. The system continuously monitors water conditions, automatically adjusts pressure to reduce waste, and gives staff the ability to remotely shut off water in an emergency. This review looked at how that system could be attacked, and what would happen if it were.

Threat modeling matters here because the risks aren't abstract. The hotel's prior \$4.2 million ceiling-collapse incident happened because a real alert wasn't trusted — the technology worked, but the surrounding system failed. A security compromise could cause the same kind of harm deliberately: a false "all clear" that hides a real leak, or a fake emergency command that cuts water to 500 occupied rooms.

Our top three findings: (1) the dashboard that controls gates and shutoff is only as strong as a single password — a successful phishing email could hand an attacker full control; (2) the channel that carries shutoff commands does not currently verify who sent them, meaning a convincing fake command could trigger an unwanted shutoff; and (3) a flood of junk traffic aimed at the system could knock out monitoring across all three water lines at once, at the exact moment a real problem might go unnoticed. We recommend addressing all three before the system is considered fully secure

Section 2: System Overview

The Grand Marina's HYDROLOGIC deployment consists of:

- A 500-room luxury hotel (Hydroficient customer)
- 3 HYDROLOGIC flow management devices — one per water service line (Main Building, Pool/Spa, Kitchen/Laundry)
- Cloud-based monitoring and control (data ingestion, storage, processing)
- A web dashboard used by operators and hotel management
- Remote gate-adjustment and emergency shutoff capability, triggered from the dashboard

Data Flow:

None

[HYDROLOGIC Devices] → [Cloud API] → [Dashboard]



[Gate Controls] [Database]

[Emergency Shutoff] [Reports]

Section 3: Asset Inventory

List the key assets and their CIA priorities (use your work from Step 2):

Asset	Description	C Priority	I Priority	A Priority
HYDROLOGIC Devices	3 flow management units	Medium	Critical	High
Web Dashboard	Operator monitoring interface	High	High	Medium
Cloud API	Device-to-cloud communication	Medium	Critical	High
Remote Controls	Gate adjustments, emergency shutoff	Low	Critical	Critical
Consumption Data	Savings reports, billing records	Medium	Medium	Low

Section 4: STRIDE Analysis

This is the core of your threat model. For **each major component**, analyze all six STRIDE categories:

Component 1: HYDROLOGIC Devices

Threat	Scenario	Likelihood	Impact	Risk
Spoofing	An attacker introduces a rogue device publishing to hydroficient/grandmarina/device-02/flow/rate, reporting a normal 37 LPM while the real	Meduim	Critical	Critical

	Pool/Spa line is actually leaking.			
Tampering	An attacker with physical access to the Device 03 mechanical room (Kitchen/Laundry) manually alters a gate position via the local interface, changing pressure delivered to the commercial kitchen.	Low	High	Medium
Repudiation	A gate adjustment occurs on Device 01, but no operator ID is logged with the change no way to prove who authorized it.	Medium	Medium	Medium
Info Disclosure	The MQTT broker is deployed without authentication; an attacker subscribes to hydroficient/grandmarina/# and reads real-time pressure/flow data, revealing hotel occupancy patterns.	High	Medium	High
Denial of Service	An attacker floods Device 01's WiFi connection with traffic, preventing pressure/flow readings from reaching the cloud and blinding leak detection for the Main Building.	Medium	High	High
Elevation of Privilege	An attacker exploits a firmware vulnerability on a HYDROLOGIC	Low	Critical	High

	device to gain shell access, then pivots to the hotel's broader operational network.			
--	--	--	--	--

Component 2: Web Dashboard

Threat	Scenarios	Likelihood	Impact	Risk
Spoofing	An attacker phishes an operations manager with a fake "Hydroficient credential re-verification" email and logs into the dashboard using the stolen credentials.	High	Critical	Critical
Tampering	An attacker with dashboard access lowers Gate A's target position on Device 02, pushing pressure beyond safe limits.	Medium	High	High
Repudiation	An operator denies triggering an emergency shutoff; no audit log ties the shutoff command to a specific login session.	Medium	Medium	Medium
Info Disclosure	An attacker with dashboard access exports months of consumption/savings history across all three devices.	Medium	Medium	Medium
Denial of Service	An attacker floods the dashboard's login endpoint with requests during a peak period, preventing staff from checking status during an actual pressure anomaly.	Medium	High	High
Elevation of Privilege	A viewer-only account exploits a role-permission bug to gain gate-control and shutoff privileges.	Low	Critical	High

Component 3: Cloud API (Same table structure)

Threat	Scenario	Likelihood	Impact	Risk
Spoofing	Through a network/DNS misconfiguration, an attacker stands up a fake endpoint and tricks a HYDROLOGIC device into sending telemetry to the attacker's server instead of Hydroficient's cloud.	Low	High	Medium
Tampering	An attacker with access to the cloud database modifies historical pressure/consumption records, corrupting the savings calculations Marcus's contract depends on.	Low	High	Medium
Repudiation	A command is sent to a device but delivery/execution is not logged — a shutoff is disputed after the fact with no record either way.	Medium	High	High

Info Disclosure	A breach of Hydroficient's cloud database exposes telemetry and consumption data for all client properties, not just Grand Marina.	Low	Critical	High
Denial of Service	An attacker floods the ingestion API with traffic far exceeding its rated capacity, delaying or dropping real telemetry from all three devices simultaneously.	Medium	Critical	Critical
Elevation of Privilege	A Hydroficient support engineer's account is compromised (or misused) to access Grand Marina's data without an open support ticket or client authorization.	Medium	High	High

Component 4: Remote Controls (Gate/Shutoff) (Same table structure)

Threat	Scenario	Likelihood	Impact	Risk
Spoofing	An attacker impersonates the cloud backend and publishes directly to hydroficient/grandmarina/commands/device-01/shutoff, since the broker does not verify the true origin of a command.	Medium	Critical	Critical
Tampering	An attacker intercepts a legitimate {"action":"test_valve","duration":5} command in transit and modifies it to {"action":"close_valve","duration":86400} before it reaches the device.	Low	Critical	High
Repudiation	A gate is opened fully, wasting water and stressing pipes; no record proves whether it was an authorized adjustment or an attack.	Medium	Medium	Medium
Info Disclosure	An attacker eavesdrops on command topics and learns exactly how to structure a valid gate-adjustment or shutoff message for future use.	High	Medium	High
Denial of Service	During a broker flood attack, the emergency shutoff command cannot reach the device at all – the one moment it is needed most.	Medium	Critical	Critical
Elevation of Privilege	An attacker with only "adjust gate" dashboard permissions discovers they can publish directly to the shutoff topic via the broker, bypassing the dashboard's role restrictions entirely.	Low	Critical	High

Section 5: Risk Summary

List your findings by risk level:

Critical Risks:

- Spoofed emergency shutoff command (Remote Controls) — the broker doesn't verify who sends a command, so an attacker impersonating the cloud could cut water to 500 rooms with a single message.
- Compromised dashboard credentials (Web Dashboard) — phishing is common and effective, and one stolen password grants gate control, shutoff, and data export.
- Cloud API flooding (Cloud API, Denial of Service) — a single flood attack can blind monitoring across all three water lines simultaneously.
- DoS blocking the shutoff path (Remote Controls) — if the broker is overwhelmed during a genuine emergency, the safety mechanism itself becomes unavailable.
- Spoofed sensor readings masking a real leak (HYDROLOGIC Devices) — the same failure mode as the original ceiling-collapse incident, this time caused deliberately.

High Risks:

- Unauthenticated MQTT broker allowing anyone to read live sensor data (Info Disclosure)
- Denial of service against a single device's WiFi connection, blinding leak detection for one zone
- Firmware vulnerability allowing an attacker to pivot from a device into the hotel's wider network (Elevation of Privilege)
- Dashboard tampering — an authenticated attacker altering gate positions beyond safe limits
- Dashboard login flooding, preventing staff from checking status during a real anomaly
- Tampering with an in-transit command (e.g., turning a 5-second valve test into a 24-hour closure)
- Cloud database breach exposing telemetry data across all Hydroficient client properties

Medium Risks:

- Missing audit trail for gate/shutoff actions (Repudiation, multiple components)
- Bulk export of historical consumption data with no additional authorization
- Physical tampering with a device's local interface
- Fake cloud endpoint tricking a device into sending data to the wrong destination

Section 6: Recommended Mitigations

Risk	Proposed Mitigation	Implementation
Spoofed emergency shutoff command	Require mutual TLS / device certificates on the command channel, plus timestamp and nonce validation so replayed or forged commands are rejected	Medium-High – architecture change
Compromised dashboard credentials	Enable multi-factor authentication for all dashboard users	Low – configuration change
Cloud API flooding (DoS)	Add rate limiting and auto-scaling / redundancy on the ingestion API	Medium – cloud configuration
DoS blocking the shutoff path	Give command traffic a dedicated, prioritized channel; add a local manual-override fallback that doesn't depend on cloud connectivity	High – architecture change
Spoofed sensor data masking a leak	Require device certificates for MQTT broker authentication; disable anonymous publish	Medium – broker configuration
Unauthenticated broker (info disclosure)	Enforce broker authentication and TLS encryption for all topics	Medium – firmware + broker update
Dashboard login flooding (DoS)	Rate-limit the login endpoint; add WAF/CDN protection	Medium – infrastructure change
Role-permission bugs (Elevation)	Enforce strict role separation server-side; run regular access audits	Medium – application update
Repudiation gaps across components	Implement comprehensive audit logging tied to authenticated sessions for every command and configuration change	Low-Medium – application update